GIÁO TRÌNH ĐÀO TẠO LÃNH ĐẠO CÔNG NHÂN

Cấp Trung cấp · Buổi 5

An toàn số

Cybersecurity

cho nhà hoạt động nghiệp đoàn

90 phút | Học trực tuyến | Thực hành thiết lập



Công cụ chỉ là một lớp — kỷ luật của con người mới là lớp bảo vệ quan trọng nhất.

BUỔI 5 · BỨC TRANH TỔNG THỂ

An toàn số là bảo vệ con người

Phần lớn rủi ro số phòng được bằng thói quen đơn giản. Bốn nhóm nội dung của buổi học:



Nền tảng

Mô hình hóa nguy cơ; con người là lớp chính



Liên lạc & mật khẩu

App an toàn; quản lý mật khẩu; 2FA



Thiết bị & dữ liệu

Danh tính; mã hóa; Lockdown Mode



Web & cảnh giác

Duyệt web ẩn danh; VPN; chống phishing

KHỞI ĐỘNG · 7 PHÚT

Bạn đang bảo vệ tài khoản của mình bằng cách nào?

- Chỉ mật khẩu
- Mật khẩu + SMS
- App xác thực
- Chưa rõ

Poll ẩn danh · cuối buổi bạn sẽ có một bộ công cụ và thói quen tốt hơn hẳn.

Mô hình hóa nguy cơ: hỏi trước khi chọn công cụ



Bảo vệ điều gì?

Danh bạ, tin nhắn, danh tính, tài liệu.



Khỏi ai?

Kẻ tò mò, người báo lại, bên nhiều nguồn lực.



Hậu quả nếu lộ?

Mất việc, bị gây khó, ảnh hưởng người khác.



Bỏ ra bao nhiêu công?

Cân bằng an toàn và tiện dụng theo nguy cơ thật.



Nguyên tắc quan trọng nhất

Công cụ chỉ là MỘT lớp. Ứng dụng tốt nhất cũng vô ích nếu bấm link lừa đảo hay dùng mật khẩu yếu. Kỷ luật con người là lớp chính — và dữ liệu nhạy cảm, tốt nhất là giữ trong đầu.

PHẦN 2 · LIÊN LẠC AN TOÀN

Nhắn tin: chọn đúng app, luôn bật tự xóa

Signal · SimpleX · Session

Mã hóa đầu-cuối. Signal: mặc định, hợp phần lớn nhu cầu. SimpleX/Session: ẩn danh cao, không cần số điện thoại.

Dùng cho: mọi việc nhạy cảm — luôn bật tin nhắn tự xóa (≤ 1 tuần)

Telegram · Zalo · Messenger

Telegram KHÔNG mã hóa đầu-cuối mặc định; Zalo/Messenger coi như bên vận hành đọc được.

KHÔNG dùng cho việc nhạy cảm — chỉ nói chuyện chung chung

Việc nhạy cảm nhất: gặp trực tiếp — không thiết bị nào an toàn tuyệt đối (nhắc lại Sơ cấp).

Một mật khẩu chính — và một lớp khóa thứ hai

Trình quản lý mật khẩu

- Nên dùng: Proton Pass, Bitwarden (miễn phí, mã nguồn mở); KeePassXC nếu muốn ngoại tuyến
- Mật khẩu chính: một passphrase dài — chỉ giữ trong đầu
- Mỗi tài khoản một mật khẩu riêng, dài, ngẫu nhiên

Xác thực hai lớp (2FA)

Mạnh nhất: khóa phần cứng

YubiKey/FIDO2 — chống cả phishing

Rất tốt: app mã nguồn mở

Aegis (Android), Ente Auth (đa nền tảng)

Dùng được, có lưu ý

Proton/Google/MS Auth — sync Google KHÔNG E2E

Tránh: SMS

Dễ bị chiếm số (SIM swapping)

Luôn lưu mã khôi phục (recovery codes) ở nơi an toàn.

Tách danh tính · lưu trữ an toàn

Nhiều danh tính

- Tách danh tính hoạt động khỏi cá nhân
- Email, tên hiển thị riêng
- Không liên kết chéo, không dùng lại ảnh/số

Lưu trữ nhạy cảm

- Tài liệu nhạy cảm: Proton Drive (E2E)
- Ít lưu càng tốt
- Tốt nhất: giữ trong đầu

Nối lại Buổi 2: phân tách danh tính chính là “ngăn cách/một đầu mối” trong thế giới số — một danh tính lộ không kéo sập phần còn lại.

Khóa chặt điện thoại và laptop

Mã hóa ổ cứng

BitLocker (Windows) / FileVault (macOS): mất máy vẫn không đọc được dữ liệu.

Khóa màn hình mạnh

PIN 6+ số hoặc passphrase, không chỉ vân tay. Sinh trắc học đôi khi dễ bị ép mở hơn.

Lockdown Mode

Trên iPhone/iPad và Mac: bật Chế độ Khóa nếu bạn thuộc nhóm nguy cơ cao.

Cập nhật thường xuyên

Cài bản cập nhật sớm — một trong những việc bảo vệ hiệu quả nhất.

Duyệt web ẩn danh — và VPN đáng tin

Trình duyệt

Điện thoại (hằng ngày)

DuckDuckGo — dễ xóa dữ liệu

Laptop (hằng ngày)

Brave / LibreWolf — chặn theo dõi

Việc nhạy cảm, ẩn danh

Tor Browser thật

Chống nhận dạng + VPN

Mullvad Browser

VPN

- Miễn phí đáng tin nhất: ProtonVPN — kiểm toán, không log, không giới hạn dữ liệu
- Cảnh báo: phần lớn VPN miễn phí bán dữ liệu. TunnelBear miễn phí chỉ ~2GB/tháng
- Mạnh nhất (trả phí): Mullvad, ProtonVPN
- VPN không phải phép màu: không ẩn danh tuyệt đối

PHẦN 4 · NHẬN DIỆN LỪA ĐẢO

Phishing — mắt xích yếu nhất, dễ phòng nhất

Đa số vụ mất tài khoản không đến từ "hack" cao siêu, mà từ một tin nhắn/trang giả.

Dấu hiệu

- Tạo cảm giác khẩn cấp: "tài khoản sắp bị khóa"
- Link lạ, địa chỉ gần giống thật nhưng sai một chút
- Yêu cầu nhập mật khẩu hoặc mã 2FA qua link
- Giả danh người quen, cấp trên, dịch vụ bạn dùng

Ba quy tắc chống phishing

1. Không bấm link lạ — tự gõ địa chỉ trang web.
2. Xác minh qua kênh khác trước khi làm gì.
3. Không ai cần mật khẩu của bạn. Khóa phần cứng chống cả phishing.

PHẦN 5 · TÓM LƯỢC

Mười nguyên tắc vàng

1. Cập nhật hệ điều hành, ứng dụng, thiết bị thường xuyên
2. Mỗi tài khoản một mật khẩu dài, duy nhất; dùng trình quản lý
3. Bật 2FA; ưu tiên app mã nguồn mở/khóa phần cứng, tránh SMS
4. Việc nhạy cảm chỉ qua Signal/SimpleX/Session + tự xóa
5. Không bấm link lạ; xác minh trước khi tin (phishing)
6. Mã hóa ổ cứng; khóa màn hình mạnh
7. Bật Lockdown Mode nếu nguy cơ cao
8. Tài liệu nhạy cảm mã hóa (Proton Drive); tốt nhất trong đầu
9. Tách danh tính hoạt động khỏi cá nhân
10. Công cụ chỉ là một lớp — con người là lớp bảo vệ chính

Thiết lập ngay hôm nay

Bắt tay làm ngay tại lớp — an toàn số chỉ có giá trị khi được thiết lập, không phải chỉ nghe.



Cài & bật

Cài Signal (hoặc SimpleX/Session), bật tin nhắn tự xóa.



Quản lý mật khẩu

Cài trình quản lý; đặt passphrase chính; đổi 1 mật khẩu quan trọng.



Bật 2FA

Bật cho email; lưu mã khôi phục.



Khóa thiết bị

Bật mã hóa ổ cứng và khóa màn hình mạnh.

Dùng "Checklist thiết lập an toàn số" (Phụ lục 2) để hoàn tất phần còn lại ở nhà.

TỔNG KẾT · 3 ĐIỀU CẦN NHỚ

Ba điều cần nhớ

Biết mình bảo vệ gì, khỏi ai (mô hình hóa nguy cơ) rồi mới chọn công cụ cho vừa sức.

Bộ công cụ nền: app nhắn tin an toàn · quản lý mật khẩu + 2FA · mã hóa ổ cứng · Proton Drive · trình duyệt riêng tư + VPN đáng tin.

Công cụ chỉ là một lớp — cập nhật, cảnh giác phishing, kỷ luật con người mới giữ bạn an toàn.

Bài tập về nhà

- Hoàn tất Checklist thiết lập an toàn số cho thiết bị của mình.
- Chuyển ≥ 5 tài khoản quan trọng sang mật khẩu mạnh + 2FA.